SOFTWARE PROJECT REPORT

waapi

Commercial multi-tenant WhatsApp HTTP API (unofficial, Baileys-based) — closed-beta software status through Phase 4.

Phase 1–3 complete | Phase 4 ~85–90% Tier-1 | Monorepo pnpm

Document type: Project report (overview for handoff / Claude)

Companion doc: Source Code Documentation PDF

Branch tip (at generation): phase-4 @ 383b24f (+ WP-M in progress)

Date: 22 October 2026

Classification: Internal engineering — no secrets

1. Executive summary

waapi is a pnpm monorepo that exposes a Fastify `/api/v1` API and React dashboard for managing unofficial WhatsApp sessions (Baileys), outbound text send, HMAC-signed webhooks, invite-gated signup, trial billing, and an internal admin CLI. A static marketing site (`apps/site`) is built for Cloudflare Pages.

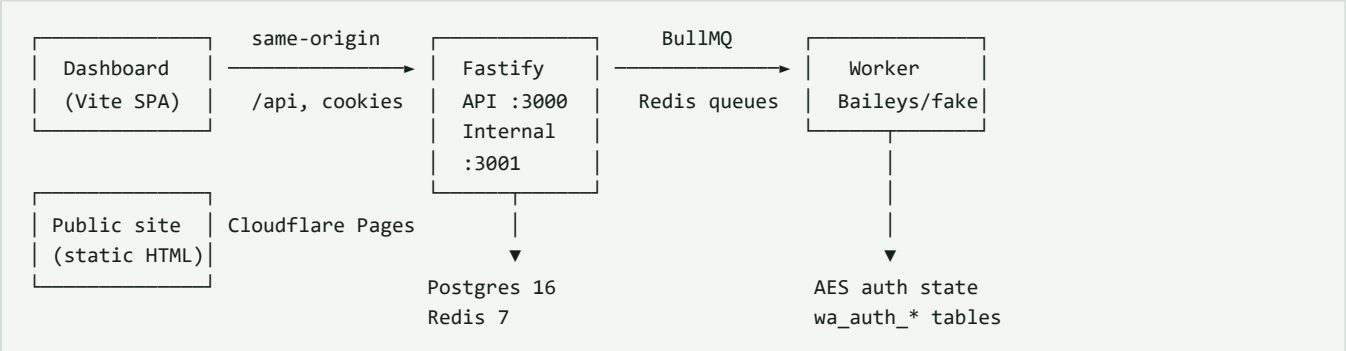
Phases 1–3 (worker, API, dashboard) are shipped. Phase 4 closed-beta work packages A–G, J, L are merged into `phase-4` . WP-M (security pass) and the final `phase-4 → main` PR remain; Tier-2 media/groups and webhook parity are stretch.

> **Product disclaimer:** Unofficial client. Not affiliated with WhatsApp or Meta. Account ban risk is real and disclosed on the public site footer and legal drafts.

2. Goals of closed beta

- Invite-only signup with Turnstile; terms acceptance stored at register.
- Deterministic `WA_DRIVER=fake` for CI/e2e without live WhatsApp.
- Trial billing (default 3 days, 1 session) with 402 enforcement when expired.
- Ops: preflight env check, encrypted off-box backups, Origin CA nginx, runbook.
- Never log/store message bodies, tokens, or secrets in plaintext application logs.

3. Architecture overview



Component	Role
`apps/api`	Auth, sessions, send, webhooks, billing, internal admin
`apps/worker`	Session lifecycle, QR, send-text jobs, Baileys/fake driver
`apps/dashboard`	Operator UI (sessions, messages, settings, billing)
`apps/site`	Prerendered marketing + legal (DRAFT)
`packages/db`	Drizzle schema + numbered migrations 0000–0010
`packages/shared`	Zod schemas, plans, brand, error codes

4. Phase delivery history

Phase	Scope	Status
1	Worker, encrypted auth state, CLI, compose, vitest	Done
2	API auth, sessions, send, webhooks, SSRF, outbox, rate limits	Done
3	Dashboard SPA, cookies/CSRF, Turnstile, smoke e2e	Done — tagged `phase-3-final`
4	Closed-beta: fake driver, invites, email UX, account/session UX, billing, admin CLI, site/legal, go-live prep, security	~85–90% Tier-1

5. Phase 4 work packages

WP	Name	Tier	Result
A	Fake WhatsApp driver + Playwright smoke	1	Merged
B	Closed beta gate (`SIGNUPS_MODE` , invite codes)	1	Merged — migration 0008
C	Email UX (`PUBLIC_APP_URL` , HTML/text templates)	1	Merged
D	Account lifecycle (password, resend verify, delete)	1	Merged
E	Session UX (disconnect/logout/delete/rename, QR expiry)	1	Merged
F	Billing core (trial, plans, Paddle sandbox adapter)	1	Merged — migration 0009
G	Admin CLI (internal HTTP + `pnpm admin`)	1	Merged
J	Public site + legal + terms at signup	1	Merged — migration 0010
L	Go-live prep (preflight, encrypted backup, nginx Origin CA)	1	Merged — docs/scripts only
M	Security pass	1	In progress
H	Media + groups	2	Not started (stretch)
I	Webhook event parity	2	Not started (stretch)

Process: test-first per WP; merge to `phase-4` only when CI green; never merge to main until final PR; never `--admin` .

6. Product features (what exists)

6.1 Auth & tenancy

- Register / login / refresh / logout with JWT access + HttpOnly refresh cookie
- CSRF double-submit on cookie-mode refresh/logout
- Email verify + password reset (Resend/SMTP/console drivers)

- `SIGNUPS_MODE=open|invite|closed` (default invite)
- Terms checkbox → `users.terms_version` + `terms_accepted_at`
- PATs and per-session API keys; account-scoped queries (tenant isolation tests)

6.2 Sessions & messaging

- Create / connect / disconnect / logout / delete / rename
- QR via Redis pub/sub; fake driver for CI
- Send text with idempotency; message logs without body retention in app logs
- Webhook endpoints with HMAC signatures; SSRF-safe URL checks; encrypted outbox

6.3 Billing

- Plans in `packages/shared/src/plans.ts` (trial/starter/pro/enterprise)
- States: trialing / active / past_due / canceled / expired + grace
- 402 `BILLING_EXPIRED` on create/send when expired
- `BILLING_PROVIDER=manual|paddle`; no card data stored

6.4 Ops

- `pnpm admin` — find user, suspend, set plan, revoke keys, force logout, invites
- `pnpm preflight` — production env gate (no secret echo)
- `scripts/backup-pg.sh` / `restore-pg.sh` — AES-256-CBC encrypted dumps
- `deploy/nginx.conf` — Cloudflare Origin CA + CF real_ip ranges

7. Data model (high level)

Area	Tables (selected)
Tenancy	accounts, users, refresh_tokens, personal_access_tokens
Sessions	sessions, session_api_keys, wa_auth_creds, wa_auth_keys
Messaging	message_logs, outbound_messages
Webhooks	webhook_endpoints, webhook_outbox, webhook_deliveries
Beta	invite_codes (0008)
Billing	subscriptions, billing_events (0009)
Legal	users.terms_version, terms_accepted_at (0010)
Audit	security_audit_log, login_attempts

8. Testing & CI

- Vitest unit + integration (API, worker, scripts); dashboard Vitest (jsdom)
- Playwright e2e on smoke stack (signup → verify → session → fake scan)

- GitHub Actions: `build` (lint, typecheck, migrate, test) + `gitleaks`
- Route matrix test: registered routes × auth modes must not return 5xx

9. Known gaps & risks

- WP-M security pass not finished; final PR `phase-4 → main` not opened
- Tier-2: media/groups send; broader webhook event types
- Legal pages marked **DRAFT** — lawyer review required before public claims
- Unofficial WhatsApp protocol / ban risk
- Nothing is auto-deployed from this repo; go-live is manual VPS + Cloudflare

10. How to run locally

```
cp .env.example .env   # fill 32-byte keys
pnpm install
pnpm docker:up
pnpm db:migrate && pnpm seed
pnpm dev:api
pnpm dev:worker
pnpm dev:dashboard     # http://127.0.0.1:5173
pnpm build:site        # apps/site/dist
```

11. Documents map

Path	Purpose
`docs/runbook.md`	Ops, smoke, admin, billing, go-live
`docs/design/billing.md`	Billing design
`docs/reports/waapi-project-report.pdf`	This report
`docs/reports/waapi-source-code-documentation.pdf`	Source tree & module guide
`.cursor/rules/*.mdc`	Agent constraints (gmb/deadletter separate)

Generated for engineering handoff. Contains no production secrets, tokens, or message bodies. Brand name is env-driven (`BRAND_NAME`); default fallback `waapi` .